

NARRATIVA EXPLICATIVA GQM + PRAGMATIC

Por Qué Medir Bien es Más Difícil que Atacar Bien

Kit GQM+PRAGMATIC CAPEC-ESP · Documento C · Versión 1.0 · Abril 2026

«Hay organizaciones que miden mucho y saben poco. Hay organizaciones que miden poco y saben bastante. Y hay organizaciones que no miden nada y confunden esa placidez con la seguridad. La diferencia entre los tres grupos la determinan, generalmente, los atacantes.»

1. EL PROBLEMA QUE ESTE MARCO RESUELVE

1.1 La paradoja de las métricas de ciberseguridad

Las organizaciones españolas en su conjunto producen una cantidad ingente de datos sobre sus incidentes de seguridad. INCIBE registró 122.223 en 2025. Pero la mayoría de esos datos son reactivos: contabilizan lo que ya ocurrió, no lo que está a punto de ocurrir. Y cuando la pregunta es "¿somos más seguros hoy que hace seis meses?", la respuesta que obtiene el Consejo de Administración es, con una frecuencia que debería avergonzar al sector, alguna variación de "creemos que sí".

El problema tiene nombre técnico: **ausencia de trazabilidad entre objetivos y métricas**. Medimos lo que podemos medir, no lo que debemos medir. Y luego, con notable creatividad, interpretamos esas métricas como si respondieran a las preguntas estratégicas que realmente importan.

GQM es la respuesta a ese problema. No es un framework más: es la disciplina de empezar por el objetivo antes de decidir qué medir.

1.2 La paradoja de los indicadores CAPEC

CAPEC v3.9 contiene 559 patrones de ataque. Cada uno incluye un campo `Typical_Severity` y un campo `Likelihood_Of_Attack`. En teoría, cualquier organización podría extraer de esos dos campos una matriz de riesgo inmediata y objetiva.

En la práctica, ¿cuántas organizaciones lo hacen? La encuesta del Documento A del kit anterior vino a medir exactamente eso. Y la hipótesis de partida —que el porcentaje es sorprendentemente bajo— no es pesimista: es una estimación conservadora basada en la brecha documentada entre disponibilidad de frameworks y adopción real en el sector.

PRAGMATIC viene a responder una pregunta diferente pero complementaria: no "¿cuántas organizaciones usan CAPEC?", sino "¿las métricas que derivan de CAPEC merecen ser usadas?". Porque no todos los indicadores posibles tienen la misma calidad. Algunos predicen incidentes futuros con notable precisión (MTTD, tasa de clic en phishing). Otros son proxies débiles que dan sensación de medición sin proporcionar información real (número de políticas aprobadas, horas de formación completadas sin evaluación de eficacia).

El resultado de aplicar PRAGMATIC a los 24 indicadores del marco es revelador: la mejor métrica del catálogo (M-NET-1.2, certificados con algoritmos vulnerables) obtiene un 4,8 sobre 5 y puede implementarse con herramientas gratuitas en menos de una jornada. La peor métrica aceptable (M-AI-1.2, madurez del proceso de Prompt Injection Testing) obtiene un 3,1 y requiere reformulación de sus criterios antes de ser fiable.

Eso, en sí mismo, ya es información accionable.

2. LA TRAZABILIDAD: EL HILO DE ARIADNA ENTRE LA POLÍTICA Y EL DATO

2.1 Del objetivo nacional al dato técnico: cuatro pasos que la mayoría no da

La Estrategia Nacional de Ciberseguridad de España establece como objetivo reducir el impacto de los ciberataques en infraestructuras críticas. Es un objetivo noble, bien intencionado y completamente inmedible si no se traduce en preguntas operacionales y de ahí en métricas técnicas concretas.

El árbol GQM hace ese recorrido en cuatro pasos:

OBJETIVO NACIONAL: "Reducir el impacto en infraestructuras críticas"

↓
GOAL GQM: "Analizar la cobertura de controles frente a patrones CAPEC de alta severidad en entornos OT, con el propósito de detectar brechas de protección antes de que sean explotadas"

↓
QUESTION: "¿Qué porcentaje de activos OT críticos están segmentados del entorno IT según el modelo Purdue o IEC 62443?"

↓
METRIC: M-OT-1.1 = (Activos_OT_segmentados_verificados / Total_activos_OT_críticos) × 100

Umbral verde: 100% · Frecuencia: Trimestral

Sin este recorrido, el objetivo nacional es una declaración de intenciones. Con él, es un programa de medición con responsable asignado, frecuencia definida y umbral que activa alarmas cuando se supera.

2.2 El coste de no hacer este ejercicio

El informe de IBM sobre el coste de las brechas de seguridad (2024) estima el coste medio global de un incidente en 4,88 millones de dólares. Pero hay una estadística menos citada en el mismo informe: las organizaciones que utilizaban métricas de seguridad avanzadas y análisis de riesgo cuantitativo tenían un coste de brecha un 39% inferior a las que no las usaban.

El 39% de 4,88 millones son 1,9 millones de dólares de diferencia por incidente. Si el kit GQM+PRAGMATIC cuesta, en horas de consultoría y herramientas, 50.000 euros de implementación, el umbral de rentabilidad es evitar 0,026 incidentes graves. Es decir, tiene ROI positivo si previene o reduce el impacto de cualquier incidente grave en cualquier organización que lo implemente.

Esta aritmética brutal es la que convierte la gestión de métricas de calidad en un argumento de negocio, no solo en una virtud técnica.

3. POR QUÉ PRAGMATIC ES EL CONTRATO PRENUPCIAL

Hay una trampa clásica en la gestión de métricas de ciberseguridad: seleccionar los indicadores más fáciles de recopilar, no los más informativos. El número de parches aplicados este mes. El número de tickets de soporte de seguridad cerrados. El porcentaje de empleados que completaron el módulo de formación de 20 minutos.

Estas métricas tienen algo en común: son fáciles de producir, cómodas de presentar y esencialmente inútiles para predecir si la organización va a sufrir un incidente grave la semana próxima.

PRAGMATIC actúa como el auditor incómodo que pregunta, para cada métrica propuesta:

- "¿Predice algo?" — Si no predice el futuro, es una métrica de confort, no de seguridad
- "¿Genera acciones?" — Si un cambio en el valor no desencadena ninguna respuesta organizacional, ¿para qué se mide?
- "¿La puede manipular el que la genera?" — Si el equipo que mide también controla lo que se mide, los incentivos están alineados para que el número siempre sea bueno

El criterio **Independiente** de PRAGMATIC es el más incómodo políticamente. La tasa de clic en simulaciones de phishing obtuvo un 3 sobre 5 en independencia precisamente porque el equipo de seguridad diseña las simulaciones y puede calibrar su dificultad. Una empresa que quiere mejorar artificialmente su métrica tiene un vector de manipulación evidente: hacer simulaciones más fáciles. La solución no es no medir; es auditar la dificultad de las simulaciones con criterios objetivos externos.

4. LAS MÉTRICAS QUE LOS ADVERSARIOS RESPETAN

Hay una forma de evaluar intuitivamente si una métrica de seguridad es buena: preguntarse si el adversario, si pudiera ver ese número, lo interpretaría como una señal de vulnerabilidad o de robustez.

M-NET-1.2 (certificados con algoritmos vulnerables): El atacante que hace reconocimiento sobre una organización y encuentra que tiene 15 certificados SHA-1 activos lee exactamente lo que la métrica mide: hay 15 comunicaciones que puede interceptar y descifrar con herramientas accesibles. Si la métrica es 0, no hay nada que interceptar.

M-SC-1.3 (MTTR de vulnerabilidades supply chain): El atacante que publica un exploit para XZ Utils y espera dos meses antes de usarlo está apostando a que el MTTR del objetivo es > 60 días. Si la métrica es < 7 días, la ventana de explotación es tan corta que el ataque deja de ser rentable.

M-IS-1.1 (tasa de clic en phishing): El actor que prepara una campaña de spear phishing contra una organización hace exactamente el mismo cálculo que la métrica mide: ¿qué porcentaje del personal va a picar? Si la tasa de la organización es 3%, necesita enviar muchos mensajes o mejorar mucho el señuelo. Si es 25%, el ataque funciona con cualquier phishing estándar.

Las buenas métricas de seguridad son aquellas que, si fueran públicas, el adversario usaría para decidir si atacar o buscar un objetivo más fácil.

5. EL HORIZONTE: HACIA UN SISTEMA DE INDICADORES CAPEC NACIONAL

5.1 Lo que España tiene

El INCIBE publica anualmente estadísticas de incidentes. El CCN-CERT publica indicadores del estado de la ciberseguridad en el sector público. ENISA publica el Threat Landscape europeo. Son fuentes valiosas, pero ninguna ofrece un sistema de indicadores que vincule los patrones de ataque con los niveles de madurez de las organizaciones y los objetivos estratégicos nacionales.

5.2 Lo que el kit propone añadir

El IGM-CAPEC, calculado sobre los 24 indicadores del marco GQM+PRAGMATIC, puede convertirse en la métrica nacional de referencia para la postura de seguridad de las organizaciones españolas respecto a los patrones de ataque más relevantes. No como reemplazo de los marcos de cumplimiento existentes, sino como complemento que da sustancia técnica a las afirmaciones de madurez.

Si el nuevo Centro Nacional de Ciberseguridad adoptara el IGM-CAPEC como indicador de seguimiento del progreso del sector, las organizaciones tendrían un incentivo para mejorar en métricas que el adversario también comprende —en lugar de acumular políticas aprobadas y horas de formación.

5.3 El precedente europeo

ENISA ha avanzado en la creación de marcos de indicadores para la Directiva NIS2. La Comisión Europea ha encargado el desarrollo de un European Cybersecurity Index. El momento para que España posicione el IGM-CAPEC como contribución al índice europeo es ahora —mientras el ecosistema de medición aún está en construcción y la ventana de influencia permanece abierta.

6. UNA NOTA SOBRE EL RIGOR Y EL TONO

Este documento, como todos los del kit, combina el rigor metodológico que exige la investigación académica con el tono que merece un lector que ya ha pasado por suficientes documentos de ciberseguridad escritos en la voz del reglamento burocrático.

El rigor no está reñido con la claridad. La ironía no está reñida con la seriedad. Y la evidencia científica no está reñida con el reconocimiento de que muchas de las cosas que los adversarios hacen bien son exactamente las cosas que las organizaciones no miden —o peor, miden mal.

La diferencia entre ambas posiciones, cuantificada con GQM y calificada con PRAGMATIC, es lo que este kit viene a reducir.

Kit GQM+PRAGMATIC CAPEC-ESP · Documento C: Narrativa Explicativa · Versión 1.0 · Abril 2026